CYBERSECURITY REPORT

Web Security Assessment Report

Finding Analysis: SQL Error Exposure

DATE:

March 25, 2026

STATUS:

Final

PREPARED FOR:

CybersecurityPortfolio

Legal Disclaimer

This report contains confidential information regarding the security posture of the assessed environment. The findings presented are based on a point-in-time assessment and reflect the vulnerabilities discovered during the testing window. This document is intended solely for professional and educational purposes within a cybersecurity portfolio context.

FINDING 01

SQL Error Exposure

(Potential SQL Injection Indicator)

Medium Risk

SUMMARY

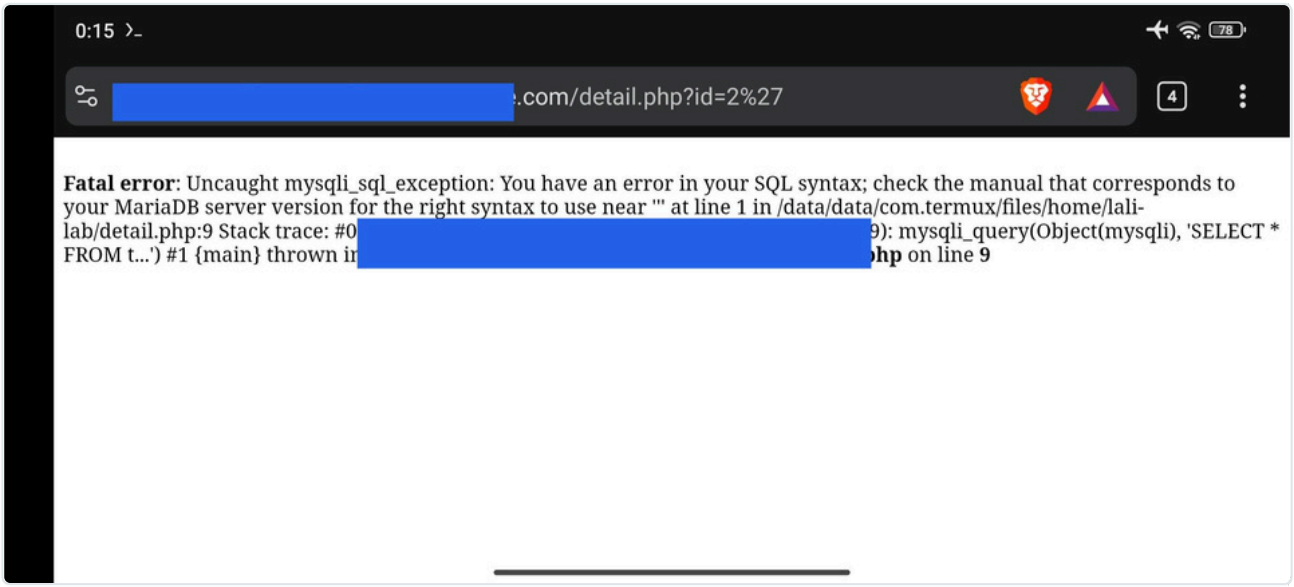
During a routine assessment of the web application, a security anomaly was identified when interacting with dynamic URL parameters. The application returned an unhandled database exception indicating malformed SQL syntax. This behavior confirms that user input is directly influencing the backend query structure without sufficient sanitization.

IMPACT

- **Application Instability:** Unhandled exceptions can lead to fatal errors and Denial of Service (DoS) for specific functionality.
- **Information Disclosure:** The exposure of internal system paths (e.g., /data/data/com.termux/...) and database technology (MariaDB) provides attackers with architectural insights.
- **SQL Injection:** • While an error is a symptom, it indicates a potential pathway toward SQL Injection.

TECHNICAL DETAILS & EVIDENCE

The issue was triggered by appending a single quote (') to the id parameter in the detail.php endpoint. The resulting database error message reveals the underlying query structure and the execution environment.



Vulnerable URL: https://[REDACTED].com/detail.php?id=2' Error Observed: Fatal error: Uncaught mysqli_sql_exception: You have an error in your SQL syntax...

RECOMMENDATION

Implement Prepared Statements: Use parameterized queries (PDO or MySQLi prepared statements) to ensure user input is never executed as code.

Strict Input Validation: Enforce type-checking on the id parameter to ensure only integer values are accepted.

Production Error Handling: Disable detailed error messages and stack traces in production. Implement a generic error page for users while logging details internally.

Global Exception Handling: Wrap database interactions in try-catch blocks to prevent fatal application crashes.

Prepared by: Abdul Mujib

Role: Security Analyst